

CompTIA Security+ SY0-701

Full-Length Practice Exam

90 Questions · Blueprint-Weighted · With Full Answer Key

A timed simulation built to the exam's real shape: up to 90 questions in 90 minutes, passing at 750/900. Questions are original, span all five domains at their official weights, and mix recall, application, and analysis tiers with performance-based questions (PBQs). Every answer explains the causal reason it is correct and why the distractors fail.

Domain	Weight	Questions
4 — Security Operations	28%	25
2 — Threats, Vulnerabilities & Mitigations	22%	20
5 — Program Management & Oversight	20%	18
3 — Security Architecture	18%	16
1 — General Security Concepts	12%	11
Total	100%	90

Timing target: ~1 minute per question. Flag and move on; return to hard items. Multiple-response questions state how many to select. PBQ answer entries include the reasoning steps.

Section 1 — Questions

Record your answers, then score against the key in Section 2.

Domain 1 — General Security Concepts (12%)

Q1. [1.1] · Recall

A bollard installed outside a data-center entrance is which control category and type?

- A. Technical / preventive
- B. Physical / preventive
- C. Physical / detective
- D. Managerial / deterrent

Q2. [1.1] · Application

An organization cannot separate duties on a small team, so it adds detailed logging and management review of that role. These reviews function as which control type?

- A. Preventive
- B. Compensating
- C. Corrective
- D. Directive

Q3. [1.2] · Recall

Which element is NOT part of the CIA triad?

- A. Confidentiality
- B. Integrity
- C. Non-repudiation
- D. Availability

Q4. [1.2] · Application

A checksum is used to confirm a downloaded file was not altered in transit. Which CIA goal does this serve?

- A. Confidentiality
- B. Integrity
- C. Availability
- D. Authentication

Q5. [1.2] · Application

In the AAA framework, which step must succeed before authorization can occur?

- A. Accounting
- B. Authentication
- C. Auditing
- D. Attestation

Q6. [1.2] · Analysis

In a zero-trust architecture, which pairing correctly separates decision from enforcement?

- A. Policy engine = enforcement; PEP = decision
- B. Policy engine = decision (control plane); policy enforcement point = enforcement (data plane)
- C. Both live in the data plane
- D. The firewall makes and enforces all decisions

Q7. [1.3] · Application

During change management, what is the primary purpose of a backout plan?

- A. To document who approved the change
- B. To restore the prior known-good state if the change fails
- C. To schedule the maintenance window
- D. To notify stakeholders

Q8. [1.3] · Recall

Which change-management artifact defines detailed, mandatory step-by-step instructions for a recurring task?

- A. Policy
- B. Guideline
- C. Standard operating procedure (SOP)
- D. Appetite statement

Q9. [1.4] · Analysis

Why do TLS sessions use asymmetric cryptography for the handshake but symmetric for the bulk data?

- A. Symmetric keys cannot encrypt data
- B. Asymmetric safely exchanges a key but is slow; symmetric is fast but needs a pre-shared key — the hybrid gets both
- C. Asymmetric is always more secure for all data
- D. Symmetric provides non-repudiation

Q10. [1.4] · Recall

What does salting a password before hashing primarily defend against?

- A. Brute-force on a live login
- B. Precomputed rainbow-table attacks on stored hashes
- C. On-path interception
- D. SQL injection

Q11. [1.4] · Application

A CA issues a certificate that binds a public key to a server identity. What core security property does this establish for a connecting client?

- A. Availability of the server
- B. Authentication of the server via a trusted third party
- C. Non-repudiation of the client
- D. Encryption of data at rest

Domain 2 — Threats, Vulnerabilities & Mitigations (22%)

Q12. [2.1] · Recall

Which threat actor is characterized by very high funding, patience, and stealthy long-term operations?

- A. Unskilled attacker
- B. Hacktivist
- C. Nation-state / APT
- D. Shadow IT

Q13. [2.1] · Application

A disgruntled administrator with legitimate access copies sensitive data before resigning. This is best classified as which threat?

- A. External nation-state
- B. Insider threat
- C. Script kiddie
- D. Supply-chain attack

Q14. [2.1] · Analysis

Why does a nation-state adversary justify heavier investment in detection and threat hunting than an unskilled attacker?

- A. They only use known exploits
- B. Their funding lets them use zero-days and dwell quietly, so prevention alone is insufficient
- C. They always announce themselves
- D. They lack resources

Q15. [2.2] · Recall

A malicious link delivered by SMS text message is which technique?

- A. Vishing
- B. Smishing
- C. Whaling
- D. Pharming

Q16. [2.2] · Application

An attacker compromises an industry news site that a target company's engineers read daily, planting malware to infect those visitors. Name the technique.

- A. Watering hole
- B. BEC
- C. Tailgating
- D. Credential stuffing

Q17. [2.2] · Analysis

Why is user awareness training considered a genuine security control rather than a soft add-on?

- A. It replaces the firewall
- B. Social engineering targets the human — an attack surface technical controls cannot patch
- C. It provides encryption
- D. It eliminates all phishing

Q18. [2.3] · Analysis

Input written past a fixed-size memory allocation overwrites the return address to redirect execution. Which vulnerability and which two mitigations?

- A. SQL injection; WAF and TLS
- B. Buffer overflow; ASLR and DEP/NX plus input validation
- C. XSS; output encoding
- D. Race condition; mutex locks

Q19. [2.3] · Application

A web form reflects unsanitized user input back into a page that other users view, running attacker script in their browsers. Which vulnerability?

- A. SQL injection
- B. Stored cross-site scripting (XSS)
- C. Buffer overflow
- D. VM escape

Q20. [2.3] · Recall

A vulnerability exploited before the vendor has released a patch is called a:

- A. Legacy flaw
- B. Misconfiguration
- C. Zero-day
- D. Race condition

Q21. [2.3] · Application

A guest VM breaks isolation and executes code on the hypervisor host. Which vulnerability class is this?

- A. VM escape
- B. SQL injection
- C. Directory traversal
- D. Smishing

Q22. [2.4] · Analysis

You observe traffic flooding a service from thousands of distinct sources until it becomes unavailable. Which attack, and which CIA leg is targeted?

- A. On-path; confidentiality
- B. DDoS; availability
- C. SQLi; integrity
- D. Phishing; authentication

Q23. [2.4] · Analysis

Authentication logs show one failed login each across 300 accounts from a single IP within two minutes. Which attack?

- A. Brute force
- B. Password spraying
- C. Rainbow table
- D. Pass-the-hash

Q24. [2.4] · Application

A standard user account suddenly executes administrative commands it never used before. Which activity does this indicate?

- A. Privilege escalation
- B. Data masking
- C. Load balancing
- D. Tokenization

Q25. [2.4] · Recall

Ransomware is most directly indicated by which observable?

- A. A slow-and-low login pattern
- B. Mass file encryption and a ransom note with a spike in file writes
- C. A single DNS record change
- D. A certificate warning

Q26. [2.5] · Application

Which control most directly enforces that a compromised account can access only the minimum resources needed?

- A. Least privilege
- B. Full-disk encryption
- C. A warning banner
- D. Load balancing

Q27. [2.5] · Analysis

A defense-in-depth design is critiqued for having three detective tools but no containment or recovery control. What is the core weakness?

- A. Too few controls overall
- B. Layers are redundant in kind, not independent — the attacker is seen at every step but never stopped or recoverable
- C. Detective controls are useless
- D. It has too much encryption

Q28. [2.5] · Recall

Segmentation primarily mitigates which stage of an attack?

- A. Initial phishing click
- B. Lateral movement across the network
- C. Password cracking
- D. Social engineering

Q29. [2.2] · Recall

An urgent email impersonating a CEO instructing finance to wire money is which specific attack?

- A. Business email compromise (BEC)
- B. Smishing
- C. Watering hole
- D. Evil twin

Q30. [2.3] · Application

A public storage bucket is left world-readable, exposing customer data. Which vulnerability type is this?

- A. Zero-day
- B. Misconfiguration
- C. Buffer overflow
- D. Race condition

Q31. [2.4] · Analysis

A user's captured session token is reused from a new location to access their account without a password. Which attack?

- A. Credential/session replay
- B. DDoS
- C. SQL injection
- D. Directory traversal

Domain 3 — Security Architecture (18%)

Q32. [3.1] · Analysis

A SaaS customer suffers a breach from a misconfigured sharing permission. Under shared responsibility, who is accountable?

- A. The provider — it runs the platform
- B. The customer — data, access, and configuration are always the customer's
- C. Neither party
- D. The provider, because it owns the hardware

Q33. [3.1] · Recall

Which architecture uses a shared host kernel and is more lightweight but offers weaker isolation than full VMs?

- A. Containerization
- B. Bare-metal servers
- C. Cold sites
- D. SD-WAN

Q34. [3.1] · Application

In a serverless model, which responsibility shifts most clearly to the cloud provider?

- A. Function code correctness
- B. Underlying OS patching and server maintenance
- C. IAM permission design
- D. Data classification

Q35. [3.1] · Analysis

Why do ICS/SCADA and many IoT devices require aggressive network segmentation rather than routine patching?

- A. They patch faster than servers
- B. They are long-lived, availability-first, and often cannot be patched safely, so isolation limits exposure
- C. They have no vulnerabilities
- D. They are always air-gapped by default

Q36. [3.2] · Application

Where should an IPS be placed to actively block an exploit at the network edge?

- A. Out-of-band on a SPAN port
- B. Inline in the traffic path at the edge
- C. On an isolated host only
- D. Inside the database

Q37. [3.2] · Recall

A screened subnet (DMZ) is used to:

- A. Store the most sensitive internal databases
- B. Host internet-facing services isolated from the internal LAN
- C. Replace the need for firewalls
- D. Provide employee wireless

Q38. [3.2] · Application

A jump server (bastion host) is placed in a management segment to:

- A. Distribute web traffic
- B. Provide a single audited, controlled entry point for administering internal systems
- C. Terminate TLS for the public site
- D. Cache DNS records

Q39. [3.3] · Analysis

To remove card numbers from an app database entirely and shrink PCI scope, which technique is best?

- A. Encryption
- B. Tokenization
- C. Masking
- D. Compression

Q40. [3.3] · Recall

Data subject to the laws of the country where it physically resides describes:

- A. Data sovereignty
- B. Data masking
- C. Data remanence
- D. Tokenization

Q41. [3.3] · Application

Which technique is one-way and therefore cannot be used where the original value must be recovered for processing?

- A. Symmetric encryption
- B. Hashing
- C. Tokenization with a vault
- D. Masking for display

Q42. [3.4] · Application

A service tolerates 4 hours of downtime and up to 24 hours of data loss. Which pairing is the most cost-appropriate?

- A. Hot site + synchronous replication
- B. Warm/cold site + daily backups
- C. Multi-region active-active
- D. Synchronous replication + hot standby

Q43. [3.4] · Recall

RPO (Recovery Point Objective) primarily drives which control decision?

- A. How fast you restore service
- B. How frequently you back up or replicate data
- C. Which firewall to buy
- D. Password length

Q44. [3.4] · Analysis

Why can a hot site still fail to meet a strict RPO?

- A. Hot sites are always slow
- B. RTO and RPO are independent — a fast-failover hot site with only nightly backups still loses up to a day of data
- C. Hot sites do not store data
- D. RPO is the same as RTO

Q45. [3.2] · Recall

SASE (Secure Access Service Edge) is best described as:

- A. A physical firewall appliance only
- B. A cloud-delivered convergence of networking (SD-WAN) and security services
- C. A backup rotation scheme
- D. A password vault

Q46. [3.2] · Analysis · PBQ

A topology: internet → edge router → DMZ (public web + email relay) → internal LAN (finance DB). Requirements: public services reachable from the internet but unable to directly touch the finance DB; admins reach internal servers only through one audited path. Which layout is correct?

```
internet --- [edge FW] --- DMZ: web + email relay
|
[internal FW]
|
internal LAN: finance DB (admin via jump server only)
```

- A. Place the finance DB in the DMZ for easy access
- B. Firewalls at the edge and between DMZ and LAN; public web/email in the DMZ; a jump server in a management segment as the sole admin path to internal servers
- C. Expose the finance DB to the internet behind the edge router only
- D. Remove the internal firewall and rely on host firewalls

Q47. [3.3] · Application · PBQ

Match protections to data states. Select the TWO correct pairings.

- A. Data in transit → TLS encryption
- B. Data at rest → full-disk / database encryption
- C. Data in use → shredding the drive
- D. Data at rest → broadcasting over HTTP
- E. Data in transit → physical destruction

Domain 4 — Security Operations (28%)

Q48. [4.1] · Application

What is the primary security benefit of applying a secure baseline image to new servers?

- A. It increases attack surface
- B. It provides a known-good, minimal config so drift is detectable and unneeded services are absent
- C. It disables all logging
- D. It removes the need for patching

Q49. [4.1] · Analysis

Why does WPA3 better resist offline dictionary attacks than WPA2?

- A. It broadcasts the PSK
- B. SAE (dragonfly) replaces the WPA2 4-way handshake so no crackable hash is exposed for offline attack
- C. It disables encryption
- D. It uses a longer SSID

Q50. [4.1] · Recall

Which MDM deployment model gives the organization the most control over the device?

- A. BYOD
- B. COPE
- C. Personal-only
- D. No management

Q51. [4.2] · Application

Per NIST SP 800-88, what must happen to media holding regulated data before disposal?

- A. Quick format then resell
- B. Sanitize (purge/crypto-erase) or physically destroy, then certify
- C. Delete files to the recycle bin
- D. Nothing if the device is old

Q52. [4.2] · Analysis

Why is an unaccounted (untracked) asset a security risk?

- A. It is automatically patched
- B. It is likely unpatched, unmonitored, and a blind spot for defenders
- C. It improves inventory accuracy
- D. It reduces attack surface

Q53. [4.3] · Analysis

Two findings: CVSS 9.9 on an air-gapped lab host with no known exploit, and CVSS 7.2 internet-facing and actively exploited. Which to remediate first?

- A. The 9.9 — highest score wins
- B. The 7.2 — exposure and active exploitation drive real risk
- C. Neither now
- D. Flip a coin

Q54. [4.3] · Recall

What does a CVE identifier provide?

- A. A severity score from 0–10
- B. A unique public identifier for a specific known vulnerability
- C. A patch download
- D. An encryption key

Q55. [4.3] · Application

A critical vulnerability has no available patch. What is the appropriate interim step?

- A. Ignore it until a patch ships
- B. Apply a compensating control (e.g., segmentation, WAF, disabling the feature) and monitor
- C. Decommission all systems
- D. Lower its CVSS score

Q56. [4.4] · Application

Which tool blocks a file containing credit-card numbers from being uploaded to a personal cloud drive?

- A. NetFlow
- B. DLP
- C. SNMP
- D. SIEM

Q57. [4.4] · Analysis

Why is a SIEM, rather than any single sensor, the place where multi-stage attacks are detected?

- A. It replaces all sensors
- B. It correlates events across sources so individually-benign events form one detectable narrative
- C. It encrypts logs
- D. It blocks traffic inline

Q58. [4.4] · Recall

SNMP traps are used to:

- A. Encrypt email
- B. Send device-initiated alerts on state changes or thresholds
- C. Tokenize card data
- D. Balance server load

Q59. [4.5] · Application

SPF and DKIM pass, yet the domain is still spoofed. DMARC is p=none. The fix?

- A. Delete SPF
- B. Set DMARC to p=quarantine or p=reject to enforce failures
- C. Disable DKIM
- D. Add a second SPF record

Q60. [4.5] · Recall

What does NAC (Network Access Control) enforce?

- A. Encryption of data at rest
- B. Devices may join the network only if they meet posture/policy requirements
- C. Firewall rule ordering
- D. Password hashing

Q61. [4.6] · Analysis

A strong password is phished. Which addition most effectively prevents recurrence?

- A. A second knowledge factor
- B. A possession or FIDO2/passkey factor, which crosses categories and resists phishing
- C. More frequent rotation
- D. A longer minimum length

Q62. [4.6] · Recall

In SAML SSO, which party issues the signed assertion the application trusts?

- A. The service provider (SP)
- B. The identity provider (IdP)
- C. The end user
- D. The firewall

Q63. [4.6] · Application

Which control set best limits the risk of privileged accounts through vaulting, just-in-time access, and session recording?

- A. DLP
- B. PAM (Privileged Access Management)
- C. NAC
- D. SPF

Q64. [4.7] · Analysis

What is the principal downside of automating a critical response workflow in a single SOAR playbook?

- A. It is slower than humans
- B. It becomes a single point of failure and propagates any logic error everywhere at once
- C. It removes the need for testing
- D. It cannot be audited

Q65. [4.8] · Analysis

Why must containment precede eradication in incident response?

- A. It does not; order is flexible
- B. Removing malware while the attacker's channel is open lets them re-enter — you must cut access first
- C. Eradication is optional
- D. Recovery always comes first

Q66. [4.8] · Recall

Preserving the integrity and documented handling of evidence for potential prosecution is called:

- A. Chain of custody
- B. Load balancing
- C. Tokenization
- D. Threat hunting

Q67. [4.9] · Analysis

Logs from firewall, web, and endpoint disagree on event times by minutes, breaking the timeline. Root cause and fix?

- A. Logs are forged; discard them
- B. Unsynchronized clocks; deploy NTP so timestamps align
- C. SIEM is broken; reinstall
- D. Time is irrelevant to forensics

Q68. [4.1] · Application

Sandboxing an untrusted application primarily provides what benefit?

- A. Faster performance
- B. Isolation so malicious behavior is contained away from the host/production
- C. Stronger passwords
- D. Data-at-rest encryption

Q69. [4.5] · Application

FIM (File Integrity Monitoring) is deployed to:

- A. Balance network load
- B. Alert on unauthorized changes to critical system files
- C. Encrypt email in transit
- D. Rotate certificates

Q70. [4.6] · Application

Which is TRUE about single sign-on (SSO)?

- A. It removes the need to protect the IdP
- B. It concentrates risk in the IdP, which must be hardened and MFA-protected
- C. It stores plaintext passwords in each app
- D. It disables federation

Q71. [4.3] · Recall

After remediating a vulnerability, what step confirms the fix worked?

- A. Close the ticket immediately
- B. Rescan/validate and report
- C. Lower the CVSS
- D. Delete the asset

Q72. [4.5] · Analysis · PBQ

Goal: permit HTTPS from anywhere to WebServer 10.0.0.20 and block all other traffic to subnet 10.0.0.0/24. Users report HTTPS is blocked. Given the rule set (top-down, first match wins), what is wrong and how do you fix it?

Rule 1: DENY ip any -> 10.0.0.0/24
Rule 2: PERMIT tcp any -> 10.0.0.20:443
Rule 3: (implicit DENY ALL)

- A. Delete Rule 2
- B. Rule 1 (broad DENY) matches first and halts evaluation before Rule 2; move the specific PERMIT above the DENY
- C. Add another implicit deny at the top
- D. Change the port to 80

Domain 5 — Program Management & Oversight (20%)

Q73. [5.1] · Recall

Which governance document is high-level management intent, broad and mandatory?

- A. Procedure
- B. Policy
- C. Guideline
- D. Standard

Q74. [5.1] · Application

A guideline differs from a standard in that a guideline is:

- A. Mandatory and specific
- B. Recommended/advisory, not mandatory
- C. A legal contract
- D. A firewall rule

Q75. [5.1] · Analysis

Why are the data owner and data custodian roles separated?

- A. To reduce headcount
- B. To enforce separation of duties — accountability (owner sets classification) is distinct from operation (custodian implements controls)
- C. Because they are the same person
- D. To avoid encryption

Q76. [5.2] · Analysis

An asset worth \$200,000 loses 50% per incident; incidents occur once every 4 years. What is the ALE?

- A. \$100,000
- B. \$50,000
- C. \$25,000
- D. \$400,000

Q77. [5.2] · Application

Following the prior item, a control costs \$30,000/yr and removes the risk. Based on ALE, is it justified?

- A. Yes, always protect valuable assets
- B. No — \$30,000 cost exceeds the \$25,000 ALE removed
- C. Yes, it lowers SLE
- D. Insufficient information

Q78. [5.2] · Recall

Which risk treatment strategy is used when buying cyber-insurance to offload financial impact?

- A. Accept
- B. Avoid
- C. Transfer
- D. Mitigate

Q79. [5.2] · Recall

MTBF measures:

- A. Mean time to repair a failed component
- B. Mean time between failures of a system
- C. Recovery point objective
- D. Annualized loss

Q80. [5.3] · Application

Before onboarding a SaaS vendor handling sensitive data, which is the strongest contractual protection to include?

- A. A verbal assurance
- B. A right-to-audit clause plus breach-notification requirements
- C. No contract
- D. A single one-time scan

Q81. [5.3] · Analysis

Why is continuous vendor monitoring necessary rather than one-time due diligence?

- A. Vendors never change
- B. A vendor's posture drifts after onboarding (new subprocessors, breaches, lapsed controls), so trust must track current evidence
- C. It reduces the need for contracts
- D. It eliminates all supply-chain risk

Q82. [5.3] · Recall

Which agreement is a non-binding statement of intent between parties?

- A. SLA
- B. MOU
- C. MSA
- D. NDA

Q83. [5.4] · Application

Under GDPR, an entity that determines the purpose and means of processing personal data is the:

- A. Data processor
- B. Data controller
- C. Data custodian
- D. Data subject

Q84. [5.4] · Analysis

Why can an organization be fully compliant yet still insecure?

- A. Compliance and security are identical
- B. Compliance proves you meet a defined bar; it does not guarantee actual risk reduction beyond that bar
- C. Security is unnecessary if compliant
- D. Regulations cover every threat

Q85. [5.4] · Recall

The privacy principle allowing individuals to request deletion of their personal data is the:

- A. Right to be forgotten
- B. Right of first refusal
- C. Chain of custody
- D. Least privilege

Q86. [5.5] · Analysis

A regulator needs an objective control evaluation; separately you want to test SOC detection of an unknown intruder. Which two?

- A. Internal audit; white-box test
- B. External audit; black-box (unknown-environment) pen test
- C. Self-attestation for both
- D. White-box test; internal audit

Q87. [5.5] · Recall

In penetration testing, a "known environment" (white-box) test means the tester:

- A. Has no prior information
- B. Has full internal knowledge of the target
- C. Only performs reconnaissance
- D. Cannot exploit anything

Q88. [5.5] · Application

A formal written declaration of audit findings provided to stakeholders is called:

- A. Attestation
- B. Reconnaissance
- C. A backout plan
- D. A risk register

Q89. [5.6] · Application

Which metric best shows a security-awareness program is improving detection coverage over time?

- A. Number of firewalls
- B. Rising phishing-report rate alongside a falling click rate
- C. Total emails sent
- D. Server uptime

Q90. [5.6] · Recall

Recognizing and reporting anomalous behavior is trained under which program?

- A.** Security awareness
- B.** Change management
- C.** Load balancing
- D.** Tokenization

Section 2 — Answer Key & Explanations

Each entry: correct answer, the causal reason it is right, and why the distractors are wrong. PBQ entries include reasoning steps.

Q	Ans	Q	Ans	Q	Ans	Q	Ans	Q	Ans
1	B	19	B	37	B	55	B	73	B
2	B	20	C	38	B	56	B	74	B
3	C	21	A	39	B	57	B	75	B
4	B	22	B	40	A	58	B	76	C
5	B	23	B	41	B	59	B	77	B
6	B	24	A	42	B	60	B	78	C
7	B	25	B	43	B	61	B	79	B
8	C	26	A	44	B	62	B	80	B
9	B	27	B	45	B	63	B	81	B
10	B	28	B	46	B	64	B	82	B
11	B	29	A	47	A, B	65	B	83	B
12	C	30	B	48	B	66	A	84	B
13	B	31	A	49	B	67	B	85	A
14	B	32	B	50	B	68	B	86	B
15	B	33	A	51	B	69	B	87	B
16	A	34	B	52	B	70	B	88	A
17	B	35	B	53	B	71	B	89	B
18	B	36	B	54	B	72	B	90	A

Detailed explanations

Q1 [1.1] · Recall Correct: B

Why: A bollard is a physical barrier that stops vehicles before they reach the building — physical category, preventive type.

Distractors: A: it is not technology-enforced. C: it prevents, it does not detect. D: it is not a policy/administrative control.

Q2 [1.1] · Application Correct: B

Why: When the ideal control (separation of duties) is infeasible, an alternate providing comparable assurance is compensating.

Distractors: A: review detects, it does not prevent the action. C: corrective restores after harm. D: directive instructs behavior.

Q3 [1.2] · Recall Correct: C

Why: Non-repudiation is an additional goal (the extra leg in CIANA), not one of the three CIA elements.

Distractors: A/B/D are the three CIA legs.

Q4 [1.2] · Application Correct: B

Why: Verifying the data is unchanged from its original state is integrity.

Distractors: A: no secrecy is provided. C: no availability concern. D: it checks the data, not an identity.

Q5 [1.2] · Application Correct: B

Why: You cannot grant appropriate access (authorization) until identity is proven (authentication) — the order is causal.

Distractors: A/C: accounting/auditing records activity afterward. D: attestation is a compliance declaration, unrelated to this order.

Q6 [1.2] · Analysis Correct: B

Why: The control plane (policy engine/administrator) decides; the data plane (PEP) enforces — decoupling policy from where the resource sits.

Distractors: A: reverses the roles. C: decision belongs to the control plane. D: zero trust does not rely on a single perimeter firewall.

Q7 [1.3] · Application Correct: B

Why: A backup plan ensures a failed change is reversible to the last working state, limiting outage impact.

Distractors: A: that is approval/ownership. C: that is the maintenance window. D: that is stakeholder communication.

Q8 [1.3] · Recall Correct: C

Why: An SOP is the step-by-step how-to for a task; it is mandatory and detailed.

Distractors: A: policy is high-level intent. B: guidelines are advisory. D: risk appetite is unrelated.

Q9 [1.4] · Analysis Correct: B

Why: Asymmetric solves key distribution over an untrusted link; symmetric then carries the session efficiently. Each covers the other's weakness.

Distractors: A: symmetric encrypts data very well. C: asymmetric is slower and not "always better" for bulk data. D: symmetric keys are shared, so they cannot prove a single sender.

Q10 [1.4] · Recall Correct: B

Why: A unique random salt makes each hash unique, defeating precomputed rainbow tables.

Distractors: A: salting does not slow live guessing (rate limiting/MFA does). C/D: unrelated attack classes.

Q11 [1.4] · Application Correct: B

Why: PKI lets a client trust that the public key truly belongs to the named server, because a trusted CA signed the binding — server authentication.

Distractors: A: certificates do not provide availability. C: it authenticates the server, not the client. D: it enables transit encryption/key exchange, not at-rest storage.

Q12 [2.1] · Recall Correct: C

Why: Nation-state/APTs are well-funded, sophisticated, and persistent.

Distractors: A: low skill, noisy. B: ideological, publicity-seeking. D: internal convenience risk, not a funded adversary.

Q13 [2.1] · Application Correct: B

Why: A trusted individual abusing authorized access is an insider threat.

Distractors: A: the actor is internal. C: the actor has legitimate access, not borrowed tools. D: no third-party vendor involved.

Q14 [2.1] · Analysis Correct: B

Why: Because APTs can burn unknown exploits and stay hidden, detection depth and hunting are needed to find what prevention misses.

Distractors: A: that describes commodity actors. C: APTs are stealthy. D: they are highly resourced.

Q15 [2.2] · Recall Correct: B

Why: SMS-based phishing is smishing.

Distractors: A: vishing is voice. C: whaling targets executives (usually email). D: pharming redirects DNS/traffic.

Q16 [2.2] · Application Correct: A

Why: Compromising a site the target group frequents to infect them is a watering-hole attack.

Distractors: B: BEC is email impersonation. C: tailgating is physical. D: credential stuffing reuses breached creds.

Q17 [2.2] · Analysis Correct: B

Why: Humans are outside the trust boundary technical controls enforce; training measurably lowers click rates and raises reporting.

Distractors: A: it complements, not replaces, technical controls. C: no encryption involved. D: it reduces, never eliminates, risk.

Q18 [2.3] · Analysis Correct: B

Why: This is a classic buffer overflow. ASLR randomizes memory locations and DEP/NX marks memory non-executable; input validation stops the overlong write.

Distractors: A/C/D: wrong vulnerability class for a memory-boundary write.

Q19 [2.3] · Application Correct: B

Why: Script that executes in other users' browsers via a trusted site is XSS (stored, since it persists for other viewers).

Distractors: A: SQLi targets the database. C: memory-boundary issue. D: hypervisor isolation break.

Q20 [2.3] · Recall Correct: C

Why: A zero-day is exploited before a fix exists; no signature yet.

Distractors: A: legacy is outdated but known. B: misconfiguration is a settings error. D: timing-of-events flaw.

Q21 [2.3] · Application Correct: A

Why: Escaping guest isolation to reach the hypervisor/host is a VM escape.

Distractors: B/C: application/web attacks. D: SMS phishing.

Q22 [2.4] · Analysis Correct: B

Why: A distributed flood exhausting resources is a DDoS, targeting availability.

Distractors: A: on-path intercepts, it does not flood. C: SQLi manipulates data. D: phishing is social engineering.

Q23 [2.4] · Analysis Correct: B

Why: One attempt spread across many accounts to avoid lockout thresholds is password spraying.

Distractors: A: brute force hammers one account. C: rainbow tables crack stored hashes offline. D: pass-the-hash replays a captured hash.

Q24 [2.4] · Application Correct: A

Why: A normal account gaining/using elevated rights signals privilege escalation.

Distractors: B/D: data-protection techniques. C: availability mechanism.

Q25 [2.4] · Recall Correct: B

Why: Ransomware's signature is rapid mass encryption plus a ransom demand.

Distractors: A: that suggests spraying/APT. C: DNS attack indicator. D: on-path/MITM indicator.

Q26 [2.5] · Application Correct: A

Why: Least privilege limits each account to only what its role requires, shrinking what a compromise can reach.

Distractors: B: protects data confidentiality at rest. C: deterrent. D: availability.

Q27 [2.5] · Analysis Correct: B

Why: Effective layering needs diversity across control types (prevent/detect/contain/recover). Redundant detection leaves no way to stop or recover.

Distractors: A: count is not the issue; diversity is. C: detection is valuable but insufficient alone. D: encryption is not mentioned.

Q28 [2.5] · Recall Correct: B

Why: Segmentation isolates zones, containing lateral movement between them.

Distractors: A: awareness/email security addresses the click. C: MFA/hashing address cracking. D: training addresses social engineering.

Q29 [2.2] · Recall Correct: A

Why: Impersonating an executive by email to induce a fraudulent transfer is BEC.

Distractors: B: SMS-based. C: compromised website. D: rogue wireless AP.

Q30 [2.3] · Application Correct: B

Why: An insecure setting exposing data is a misconfiguration — a leading cloud-breach cause.

Distractors: A: no unknown flaw. C/D: memory/timing issues.

Q31 [2.4] · Analysis Correct: A

Why: Reusing a captured token to impersonate the session is a replay attack; the anomalous location is the indicator.

Distractors: B: availability flood. C: database injection. D: path traversal to unauthorized files.

Q32 [3.1] · Analysis Correct: B

Why: Even in SaaS, the customer always owns data classification, access, and configuration.

Distractors: A/D: the provider secures the platform, not your settings. C: customers always retain those duties.

Q33 [3.1] · Recall Correct: A

Why: Containers share the host kernel — lightweight but with weaker isolation than hypervisor-based VMs.

Distractors: B: bare metal is heaviest. C: DR facility. D: WAN transport approach.

Q34 [3.1] · Application Correct: B

Why: Serverless offloads OS/server upkeep to the provider; the customer still owns code, permissions, and data.

Distractors: A/C/D remain customer responsibilities.

Q35 [3.1] · Analysis Correct: B

Why: Such systems prioritize uptime and often can't tolerate patch downtime, so segmentation contains their exposure.

Distractors: A: they patch slower. C: they have many. D: they are frequently networked, not air-gapped.

Q36 [3.2] · Application Correct: B

Why: An IPS must sit inline to drop malicious traffic in real time.

Distractors: A: SPAN is passive (IDS). C/D: would not intercept edge traffic.

Q37 [3.2] · Recall Correct: B

Why: A DMZ hosts public-facing services between two firewalls, isolating them from the internal network.

Distractors: A: sensitive data belongs internal. C: DMZs are created by firewalls. D: unrelated.

Q38 [3.2] · Application Correct: B

Why: A jump server funnels admin access through one hardened, logged path.

Distractors: A: that is a load balancer. C: reverse proxy/LB. D: DNS resolver.

Q39 [3.3] · Analysis Correct: B

Why: Tokenization replaces the value with a non-sensitive surrogate stored elsewhere, so the real data never resides in the app.

Distractors: A: keeps (scrambled) data in place, scope remains. C: display control only. D: not a security control.

Q40 [3.3] · Recall Correct: A

Why: Data sovereignty means data is governed by the jurisdiction it is stored in.

Distractors: B/D: protection techniques. C: residual recoverable data.

Q41 [3.3] · Application Correct: B

Why: Hashing is irreversible — suitable for integrity/verification but not where you must retrieve the original.

Distractors: A: reversible with the key. C: reversible via the vault mapping. D: hides for display but underlying value is retained.

Q42 [3.4] · Application Correct: B

Why: Loose RTO (4h) and RPO (24h) don't justify costly real-time infrastructure; a warm/cold site with daily backups meets both cheaply.

Distractors: A/C/D: over-provision far beyond the stated objectives, wasting cost.

Q43 [3.4] · Recall Correct: B

Why: RPO is maximum tolerable data loss, so it dictates backup/replication frequency.

Distractors: A: that is RTO. C/D: unrelated.

Q44 [3.4] · Analysis Correct: B

Why: A hot site addresses recovery time (RTO); without frequent replication, data loss (RPO) can still be large.

Distractors: A: hot sites are fast. C: they do store data. D: they are distinct metrics.

Q45 [3.2] · Recall Correct: B

Why: SASE delivers combined networking and security functions from the cloud edge.

Distractors: A: it is cloud-delivered, not a single appliance. C/D: unrelated.

Q46 [3.2] · Analysis · PBQ Correct: B

Why: Public services belong in the DMZ, bounded by firewalls on both sides so a DMZ compromise can't reach the finance DB. A jump server gives the single audited admin path.

Distractors: A/C: sensitive DBs must never sit in the DMZ or face the internet. D: removing the internal firewall destroys the DMZ↔LAN boundary.

Q47 [3.3] · Application · PBQ Correct: A, B

Why: A: TLS protects data moving across networks (in transit). B: disk/DB encryption protects stored data (at rest).

Distractors: C: shredding applies to disposal of media, not data actively in use. D: HTTP is unencrypted — the opposite of protection. E: destruction is a disposal method, not a transit control.

Q48 [4.1] · Application Correct: B

Why: A baseline makes "secure" repeatable and measurable — deviations (drift) become detectable, and unnecessary services/ports are off by default.

Distractors: A: it reduces attack surface. C: baselines enable logging. D: patching is still required.

Q49 [4.1] · Analysis Correct: B

Why: WPA3's SAE handshake does not expose a capturable value that can be brute-forced offline.

Distractors: A: it never broadcasts secrets. C: it strengthens encryption. D: SSID length is irrelevant.

Q50 [4.1] · Recall Correct: B

Why: Corporate-Owned, Personally Enabled devices are company-owned, allowing full MDM control.

Distractors: A: BYOD is personally owned, least control. C/D: not managed models.

Q51 [4.2] · Application Correct: B

Why: 800-88 requires sanitization or destruction appropriate to sensitivity, with certification for the audit trail.

Distractors: A/C: formatting/deleting leaves recoverable data (remanence). D: age does not remove data risk.

Q52 [4.2] · Analysis Correct: B

Why: You can only protect what you know you have; untracked assets escape patching and monitoring.

Distractors: A: untracked means unmanaged. C: it corrupts inventory. D: it adds hidden surface.

Q53 [4.3] · Analysis Correct: B

Why: Prioritization blends severity with exposure and exploit activity; the reachable, actively exploited flaw is the greater real risk.

Distractors: A: raw-CVSS-only prioritization is the classic error. C: the exploited external flaw is urgent. D: the contexts are clearly unequal.

Q54 [4.3] · Recall Correct: B

Why: CVE is the standardized identifier for a specific vulnerability; CVSS provides the severity score.

Distractors: A: that is CVSS. C/D: unrelated.

Q55 [4.3] · Application Correct: B

Why: When no patch exists, compensating controls reduce risk until remediation is possible.

Distractors: A: leaves the risk unaddressed. C: disproportionate. D: you cannot rescore reality.

Q56 [4.4] · Application Correct: B

Why: DLP inspects content and blocks sensitive data from leaving via cloud, email, or USB.

Distractors: A: flow metadata, not content. C: device telemetry. D: correlation/alerting, not egress blocking.

Q57 [4.4] · Analysis Correct: B

Why: Cross-source correlation turns scattered, innocent-looking events into a detectable attack chain.

Distractors: A: it consumes sensor data, not replaces it. C: not its core function. D: a SIEM does not sit inline.

Q58 [4.4] · Recall Correct: B

Why: SNMP traps push alerts when a device crosses a threshold or changes state (e.g., interface down).

Distractors: A/C/D: unrelated functions.

Q59 [4.5] · Application Correct: B

Why: p=none only monitors; enforcement (quarantine/reject) actually stops mail failing SPF/DKIM alignment.

Distractors: A/C: weaken authentication. D: multiple SPF records are invalid.

Q60 [4.5] · Recall Correct: B

Why: NAC admits devices only when they satisfy posture checks (patch level, AV, config).

Distractors: A/C/D: unrelated controls.

Q61 [4.6] · Analysis Correct: B

Why: MFA gains strength from independent categories; a possession/FIDO2 factor is not phishable like a password and (FIDO2) binds to origin.

Distractors: A: still phishable — same failure mode. C/D: do not stop a user entering the password on a fake site.

Q62 [4.6] · Recall Correct: B

Why: The IdP authenticates the user and issues the signed assertion the SP relies on.

Distractors: A: the SP consumes the assertion. C/D: not assertion issuers.

Q63 [4.6] · Application Correct: B

Why: PAM restricts, time-boxes, and records privileged use, shrinking the damage window.

Distractors: A: egress control. C: device posture. D: email authentication.

Q64 [4.7] · Analysis Correct: B

Why: Automation's leverage magnifies mistakes and concentrates risk; the pipeline needs the same change control as production code.

Distractors: A: it is faster. C: it needs more testing, not less. D: it can and should be audited.

Q65 [4.8] · Analysis Correct: B

Why: Each phase sets up the next; eradicating into an open channel invites re-entry, so contain (cut access) first.

Distractors: A: the order is causal. C: eradication is required. D: recovery follows eradication.

Q66 [4.8] · Recall Correct: A

Why: Chain of custody documents who handled evidence, when, and how, preserving its admissibility.

Distractors: B/C: unrelated. D: proactive search for undetected threats.

Q67 [4.9] · Analysis Correct: B

Why: A reliable timeline needs synchronized clocks; NTP aligns sources so causal order is readable.

Distractors: A: drift is not forgery. C: sources, not the SIEM, are the issue. D: synchronized time is foundational.

Q68 [4.1] · Application Correct: B

Why: A sandbox isolates execution, containing any malicious effects from the rest of the system.

Distractors: A: often slower. C/D: unrelated to isolation.

Q69 [4.5] · Application Correct: B

Why: FIM detects and alerts on unexpected modifications to important files (integrity).

Distractors: A/C/D: unrelated functions.

Q70 [4.6] · Application Correct: B

Why: SSO improves UX but makes the IdP a high-value target that must be strongly protected.

Distractors: A: the opposite. C: SSO avoids per-app credentials. D: SSO often enables federation.

Q71 [4.3] · Recall Correct: B

Why: Rescanning validates remediation; without it you do not know the fix succeeded.

Distractors: A: premature. C: rescoring is not validation. D: disproportionate.

Q72 [4.5] · Analysis · PBQ Correct: B

Why: First-match evaluation means the broad "deny all to subnet" matches HTTPS first and stops — the permit never runs. Specific rules must precede general ones.

Distractors: A: Rule 2 is the permit you need. C: a top deny blocks everything. D: HTTPS is 443.

Q73 [5.1] · Recall Correct: B

Why: A policy states high-level, mandatory management intent.

Distractors: A: step-by-step how-to. C: advisory. D: specific mandatory requirement.

Q74 [5.1] · Application Correct: B

Why: Guidelines are recommended best practices, not mandatory; standards are mandatory specifics.

Distractors: A: that describes a standard. C/D: unrelated.

Q75 [5.1] · Analysis Correct: B

Why: Separating who decides protection from who executes it creates a check against error and abuse.

Distractors: A: not the purpose. C: they are distinct roles. D: unrelated.

Q76 [5.2] · Analysis Correct: C

Why: $SLE = \$200,000 \times 0.5 = \$100,000$; $ARO = 0.25$; $ALE = \$100,000 \times 0.25 = \$25,000/\text{yr}$.

Distractors: A: that is the SLE. B: wrong ARO. D: multiplies incorrectly.

Q77 [5.2] · Application Correct: B

Why: A control is justified only if it reduces ALE by more than it costs; \$30k to remove \$25k is a net loss.

Distractors: A: cost/benefit decides, not asset value. C: ALE is the annual basis. D: enough data is given.

Q78 [5.2] · Recall Correct: C

Why: Insurance shifts financial risk to a third party — risk transfer.

Distractors: A: accept = take no action. B: avoid = stop the activity. D: mitigate = reduce with controls.

Q79 [5.2] · Recall Correct: B

Why: MTBF is the average time between failures (reliability); MTTR is the average repair time.

Distractors: A: that is MTTR. C: RPO is data-loss tolerance. D: ALE.

Q80 [5.3] · Application Correct: B

Why: A right-to-audit and breach-notification clauses keep the trust relationship tied to current evidence over time.

Distractors: A: unenforceable. C: leaves you exposed. D: point-in-time only; posture drifts.

Q81 [5.3] · Analysis Correct: B

Why: Point-in-time vetting goes stale; ongoing monitoring catches drift and new exposure.

Distractors: A: they change constantly. C: contracts are still needed. D: it reduces, not eliminates, risk.

Q82 [5.3] · Recall Correct: B

Why: A Memorandum of Understanding expresses intent and is generally non-binding.

Distractors: A: SLA sets measurable performance commitments. C: MSA sets binding overarching terms. D: NDA protects confidential info.

Q83 [5.4] · Application Correct: B

Why: The controller decides why and how data is processed; the processor acts on its instructions.

Distractors: A: acts on instructions. C: implements day-to-day controls. D: the individual the data is about.

Q84 [5.4] · Analysis Correct: B

Why: Compliance meets a specific standard at a point in time; real-world risk can persist outside that scope.

Distractors: A: they overlap but differ. C: security is still needed. D: regulations rarely cover every threat.

Q85 [5.4] · Recall Correct: A

Why: The right to be forgotten (erasure) lets individuals request deletion of their data.

Distractors: B: contract concept. C: evidence handling. D: access principle.

Q86 [5.5] · Analysis Correct: B

Why: Regulators require external audits for independence; a black-box pen test best simulates an unknown external attacker to test detection.

Distractors: A: internal audit lacks independence; white-box skips recon so it does not test detection. C: not objective. D: reversed.

Q87 [5.5] · Recall Correct: B

Why: White-box/known-environment testers have full internal knowledge, enabling deep, efficient testing.

Distractors: A: that is black-box. C: recon is one phase, not the definition. D: they do exploit.

Q88 [5.5] · Application Correct: A

Why: Attestation is the formal written statement of audit/assessment results.

Distractors: B: information gathering. C: change-management rollback. D: a log of risks.

Q89 [5.6] · Application Correct: B

Why: More reports plus fewer clicks means users are both resisting and surfacing threats earlier — improving early detection.

Distractors: A/C/D: unrelated to awareness effectiveness.

Q90 [5.6] · Recall Correct: A

Why: Awareness programs train users to recognize and report anomalies and phishing.

Distractors: B/C/D: unrelated domains.

Scoring: the real exam scales 100–900 and passes at 750 (~83%). Aim for 83%+ (~75/90 correct) consistently before scheduling. Original practice content built to the SY0-701 (V7), objectives v5.0 blueprint and CompTIA's authorized-materials policy — no real exam items reproduced.